NOVI CORPUS · AGENT LEGAL BODY PLATFORM

V2 Roadmap

Product & Hardening Plan · from proven testnet demo to production

VERSION 2.0 (DRAFT) · JULY 2026 · COMPILED FROM REPO DESIGN DOCS, AUDIT NOTES & THE V2 BACKLOG

Novi Corpus gives AI agents a real legal body: a Wyoming DAO LLC wrapped around a governed on-chain USDC treasury on Arc, with a human always holding the brake. V1 proved the full agent lifecycle end-to-end on testnet — onboard, fund, pay over x402, earn USDC and on-chain reputation, all through MCP. This document lists what a production-grade V2 requires, ordered by relevance: the architectural bets that define the product, the hardening needed before real money moves, then scale and polish.

> **The single highest-leverage change:** migrating agent wallets from raw EOAs to Circle smart accounts (ERC-4337 + Gas Station). It structurally deletes at least four systems V1 had to build by hand — the gas seeder, the Arc gas-estimation footgun, the fund-pocket bridge race, and the multi-step funding saga — replacing them with sponsored gas and one atomic batched operation.

● Foundational — needed before real money / mainnet ● Robustness & scale ● Product & polish

Tier 0 Flagship bets — what the product becomes

Define the V2 identity

1 A real multi-party economic loop 🔴

Today the platform impersonates every counterparty: it funds job escrow, plays the evaluator, and stands in as the paying customer, so the loop closes with no outside party. **Why it matters:** this is the line between a self-contained demo and an actual marketplace where real clients post jobs, independent evaluators score work, and real customers pay agents.

EFFORT: L | UNLOCKS: REAL REVENUE

2 EOA → Circle smart-account migration (ERC-4337 + Gas Station) 🔴

Move each agent's operator/pocket from raw externally-owned keys to Circle smart accounts with sponsored gas and atomic batched UserOps. **Why it matters:** one change removes the gas seeder, the Arc estimate-gas footgun (fixed by hand in #33), the fund-pocket bridge race, and the partial-state funding saga — the biggest complexity reduction available.

DEP: VERIFY CIRCLE SCA / GAS STATION / ERC-1271 / EIP-3009 ON ARC | SUPERSEDES: GAS-SEEDER, #32, #33

3 Custody choice: Circle Dev-Controlled + Agent Wallets (Model B) 🟠

Offer Circle Dev-Controlled Wallets as the Model-A operator (autonomous, programmatic, now confirmed on Arc) beside Turnkey, and Agent Wallets for the self-sovereign Model B where the agent holds its own signing capability. **Why it matters:** serves both custody audiences and completes the "built on Circle's full stack" story; the `custody` field already exists in the schema.

EFFORT: L | DEP: VIVIENNE — AGENT-WALLET ARC BINDING + PROGRAMMATIC HOOK

4 Circle policy engine as defense-in-depth 🟠

Enforce spending rules (per-tx, period, allowlist, review threshold) Circle-side, in addition to the on-chain caps. **Why it matters:** if policy changes are gated separately from signing, the rules bound even a fully compromised backend — a strong extra guardrail next to the treasury contract.

EFFORT: M | DEP: CIRCLE POLICY-ENGINE INDEPENDENCE

5 Trust-minimized, always-on Payment Authority 🔴

The service that checks every spend against caps/allowlist is today trusted, centralized, and a single point of failure ("if it's down, the agent can't pay"). V2 adds HA/liveness, an auditable off-chain ledger, and a verifiable execution path (TEE / ZK / on-chain checkpoints). **Why it matters:** the governor of a governed treasury shouldn't itself be unverifiable or fragile.

EFFORT: L | HARDENS: THE CORE TRUST STORY

6 Treasury-direct x402 signing (EIP-1271 / ERC-7598) 🟠

Let the treasury contract sign its own x402/Gateway authorizations, removing the hot operator EOA entirely. **Why it matters:** no hot key means a cleaner, more trustless custody model — arguably the endgame the smart-account migration points toward.

EFFORT: M | DEP: FACILITATOR SUPPORT FOR CONTRACT SIGNATURES

7 Agent-to-agent payments 🟡

Two governed agents transacting directly, and multi-source data purchases. **Why it matters:** extends nanopayments beyond the buyer/seller demo into a genuine agent economy with network effects — a differentiating capability, not just hardening.

EFFORT: M

8 x401 controller identity & KYC 🟠

Adopt x401 (Proof + Circle) as the onboarding controller-verification step: IAL2 KYC and a verifiable "who's behind this agent" credential. **Why it matters:** satisfies the mandatory natural-person-controller legal gate and sharpens the pitch — "x402 pays, x401 proves identity, Novi Corpus is what the agent legally is."

EFFORT: M | CONSUME, DON'T BUILD (PROOF ISSUER)

Tier 1 Foundational hardening

Before real money / mainnet 🔴

SMART CONTRACTS & ON-CHAIN SECURITY

1 Beacon owner → multisig / timelock 🔴

Today a single testnet EOA owns the upgrade beacon for *every* agent's manager contract. **Why it matters:** one compromised key could upgrade all agents at once — the highest-priority centralization risk before any production deploy.

2 Policy nonce & signature-replay protection 🔴

Policy actions and the ERC-8004 `AgentWalletSet` binding carry no nonce, so an authorized signature is replayable until its deadline. **Why it matters:** replay protection is table stakes for on-chain policy safety once value is at stake.

3 Guardian multisig + role rotation 🔴

The guardian and manager are single immutable keys with no rotation path; recovery today means a contract upgrade. **Why it matters:** a lost or compromised human-controller key must be recoverable without redeploying the agent.

4 Live-registry fork tests + professional audit 🔴

Only mocks are in CI; the deployed identity/job/reputation contracts are still `Mock*` placeholders. Fork-test the real ERC-8004 `register()` and re-bind paths, and commission a manual external audit. **Why it matters:** the static-analysis pass is explicitly "not a substitute for manual review" before mainnet.

5 Pre-mainnet build gates + reputation wiring 🟠

`via_ir` bytecode re-review, a Mythril run, and pinning the pragma to `0.8.24`; plus wiring the ERC-8183 reputation interfaces (interface-only stubs today) into the contracts, and a documented migration story for the intentionally-immutable treasury. **Why it matters:** closes the known pre-production checklist and makes on-chain reputation real.

BATCH: INCL. STATIC-ANALYSIS NITS

BACKEND CORRECTNESS & SAFETY

6 Onboarding saga: the create→persist double-mint window 🔴

A crash after the `createEntity` tx mines but before it's persisted causes a resume to mint a *second* agentId, orphaning the first. **Why it matters:** the single biggest correctness bug — fix by splitting broadcast/confirm, persisting the tx hash first, and adopting the existing agentId on resume.

7 Concurrency: key-claim lock + spec-hash idempotency 🔴

Two concurrent onboarding calls for the same key both mint; re-running a key silently ignores a changed spec. **Why it matters:** becomes real the moment onboarding runs multi-worker — claim the key atomically, and reject a conflicting spec instead of overwriting it.

8 Production signer + role-separated keys 🔴

The default signer is a raw local private key, and one `PLATFORM_PRIVATE_KEY` doubles as manager, job client, customer, evaluator fallback, and x402 payout. **Why it matters:** make Turnkey (or a KMS) the default and give each role its own key to contain blast radius.

9 Split the `spend` capability + cap earn 🔴

The `spend` rung currently conflates paying third parties with *provisioning* (`onboard_agent`, `fund_treasury`), and `run_job` earn has no budget/quota. **Why it matters:** real grants need least-privilege — a separate `provision/admin` rung and earn-side limits.

10 Durable replay guard, SSRF fix, auth & metadata hardening 🔴

The x402 seller's replay guard is an in-memory set (lost on restart); a documented DNS-rebinding TOCTOU can slip a blocked IP past the SSRF guard; SIWE routes need rate-limiting and burn-on-attempt; the public metadata route does synchronous DB + file reads on the event loop. **Why it matters:** the exposed surfaces a real attacker would probe first.

Tier 2 Robustness & scale

Production readiness 🟠

1 SQLite → Postgres

Every store is a single-file, single-process SQLite database (with an acknowledged race in the idempotency store). **Why it matters:** multi-instance HA and concurrent writers are impossible until this moves to a real cloud database.

2 Durable document storage + metadata backfill

Agent metadata is served from a local file store via `file://`; move to S3 / Vercel Blob (and IPFS for real decentralization), and backfill the three existing demo agents whose URIs are still `file://`. **Why it matters:** the metadata URI is baked on-chain permanently, so durable, public, verifiable hosting is essential.

3 Real job worker + event-sourced job IDs

The job worker returns a hardcoded string; job IDs are read from a simulate call rather than an emitted event. **Why it matters:** replace the placeholder with a real agent/LLM worker producing content-addressed deliverables, and read IDs from logs to be concurrency-safe.

4 Observability & alerting

Structured logs, metrics, and alerts on treasury balances, failed jobs, and platform gas outflow, plus an admin view. **Why it matters:** the platform custodies money today with no operational visibility — a production must-have. *(New recommendation.)*

5 Withdrawable Gateway balance + aggregate outflow cap

Pocket float is kept near zero because the SDK wrapper can't withdraw the Gateway-held balance, and the gas seeder has no global platform-spend ceiling. **Why it matters:** reclaims stranded capital (resolves with the smart-account work) and bounds worst-case platform outflow across all agents.

6 Cleanup: de-scope `retryOnStaleBalance`

A retry loop added to survive a revert that the #33 explicit-gas fix made deterministic and impossible. **Why it matters:** it's now dead defensive code that burns ~18s per attempt on paths that can no longer fail that way.

Tier 3 Product & UX

Experience & surface 🟡

1 Payments-history UI 🟡

Surface the x402 payments an agent makes (they persist in the ledger but appear nowhere in the UI), from a narrow spend-history card to a full money-movements timeline. **Why it matters:** closes the gap between "what the agent did" and "what the dashboard shows." Small, high-value.

2 Real x402 seller, real datasets, expanded MCP tools 🟡

Replace the flag-gated demo quote and synthetic dataset catalog with a live seller, and add MCP tools (`authorize_payment`, `agent_ask`, job/reputation). **Why it matters:** turns demo surfaces into real capabilities agents can build on.

3 In-UI "run the agent" trigger + explicit sweep tool 🟡

Add an in-dashboard trigger / autonomous background runner (this is why the Activity card is empty today), and expose earnings consolidation as an explicit `sweep_earnings` tool rather than an always-on flag. **Why it matters:** gives the human direct, legible control over the agent's activity.

4 Onboarding & developer-experience polish 🟡

Server-persist onboarding progress (currently only in `localStorage`), add live claim-status polling on bootstrap, generate a typed OpenAPI client from the Zod `AgentSpec`, and finish small interface items (connection labels, active-nav state, `governance` default). **Why it matters:** smooths the first-run and integration experience that drives adoption.

Track L Legal & compliance

Parallel · counsel-gated

Core to a "legal body," not peripheral — and almost entirely simulated in V1. These run in parallel with engineering and are gated on Wyoming-admitted counsel and Circle confirmations.

1 Real entity formation 🔴

Actual Wyoming DAO LLC filing, a real EIN (currently `STUB-NOT-FILED`), crypto-friendly banking, and legally-reviewed operating-agreement documents. **Why it matters:** without real filings the "legal body" is a demonstration, not a legal entity.

2 KYC / user-of-record + OA-to-chain mapping 🔴

Confirm the KYC "user-of-record" model for an algorithmically-managed LLC, and settle the operating-agreement-clause → on-chain mapping, the Wyoming submission format, and upgradeability disclosure. **Why it matters:** these legal-architecture questions gate a real filing (a natural-person controller is already established as mandatory).

3 Entity lifecycle & compliance monitoring 🟠

Dissolution / wind-up, the dissociation mechanic (the human settlor stepping away), inter-entity contracting, and automated compliance (annual filings, sanctions screening, SAR). **Why it matters:** a legal entity needs a full lifecycle and ongoing compliance, not just creation.

4 Multi-jurisdiction + fiat rails 🟡

Support a second jurisdiction (e.g. Marshall Islands) with unified UX, and a fiat on/off-ramp via Circle Mint. **Why it matters:** broadens addressable users beyond Wyoming and connects the treasury to the traditional financial system.

RECOMMENDED SEQUENCING — THE FIRST SIX

1. **Contracts foundation** — beacon → multisig, policy nonce, live-registry fork tests, external audit. Unblocks any real deployment.
2. **Onboarding correctness** — the double-mint window + key-claim lock. Correctness under real, concurrent load.
3. **Postgres migration** — nearly everything else assumes a real multi-writer database.
4. **Smart-account migration** — deletes the gas seeder, the estimate-gas footgun, and the bridge race in one move.
5. **Real multi-party loop** — turns the self-contained demo into an actual marketplace.
6. **x401 + Circle Dev-Controlled custody** — completes the "full Circle stack" story and the legal identity gate.

Sources. Compiled from the repository's design specs and plans (`back/docs/design/*`, `back/docs/plans/*`), the audit notes (`back/docs/audit/*`), the canonical deferred-items ledger (`back/docs/V2_HARDENING_BACKLOG.md`), `back/docs/SPEC.md`, and ongoing product discussions with Circle. Severity legend follows the backlog: 🔴 correctness / safety · 🟠 robustness / ops · 🟡 cleanup / polish.